

Kubernetes · SSO

Kubernetes 클러스터 SSO 도입기

Authentik으로 ArgoCD, Grafana, Argo Workflows, Airflow, Kubecost까지 구글 계정 하나로 통합한 과정

Jonghwa Baek



문제

서비스마다 계정이 따로

누군가 새로 합류하면 서비스마다 계정을 만들어줘야 했고, 떠날 때는 어디에 계정이 있는지 추적해서 하나씩 정리해야 했다.

ArgoCD

별도 계정

Grafana

별도 계정

Argo Workflows

별도 계정

Airflow

별도 계정

Kubecost

인증 없음 (IP 제한만)

왜 Authentik인가

3가지 후보 중 선택

Keycloak은 UI 클릭 중심이라 GitOps로 관리하기 어렵다. Authentik은 Blueprint YAML로 앱 설정, 정책, 그룹까지 코드로 선언할 수 있다.

Okta

SaaS · 유저당 과금

Keycloak

Self-hosted · UI 중심

Authentik

Self-hosted · Blueprint YAML

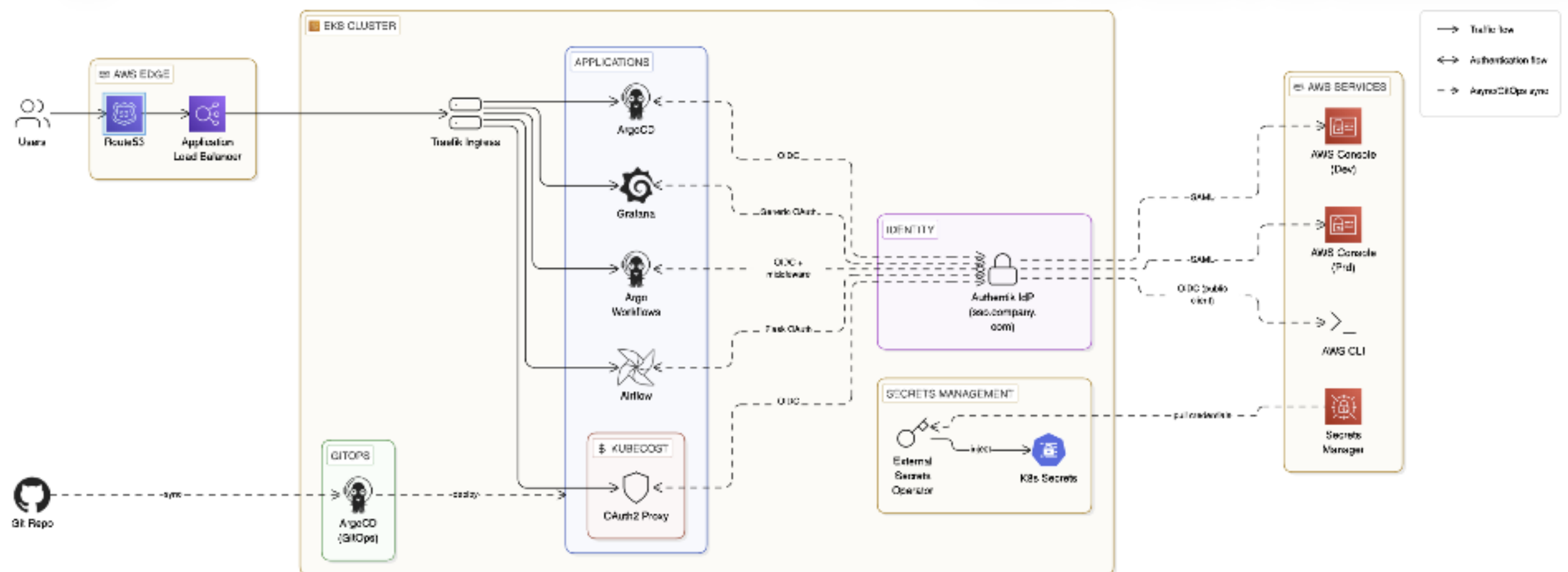
SELECT

전체 흐름

사용자 요청은 Route53 - ALB - Traefik을 거쳐 각 서비스로 라우팅된다.

각 서비스는 Authentik에 인증 요청을 보내고 OIDC/OAuth2/SAML로 처리한다.

OAuth 시크릿은 External Secrets가 AWS Secrets Manager에서 K8s Secret으로 자동 주입한다.



4가지 인증 방식

앱마다 지원하는 프로토콜이 달라서 하나의 방식으로 통일하기가 어렵다. 케이스별로 맞는 패턴을 골라야 한다.

OIDC

ArgoCD, Argo Workflows

Public Client + PKCE로 CLI 로그인까지 동일 client 사용

Generic OAuth

Grafana

role_attribute_path로 그룹 기반 권한 자동 매핑

oauth2-proxy

Kubecost

자체 인증 없는 앱 앞단에 프록시로 배치

SAML

AWS Console

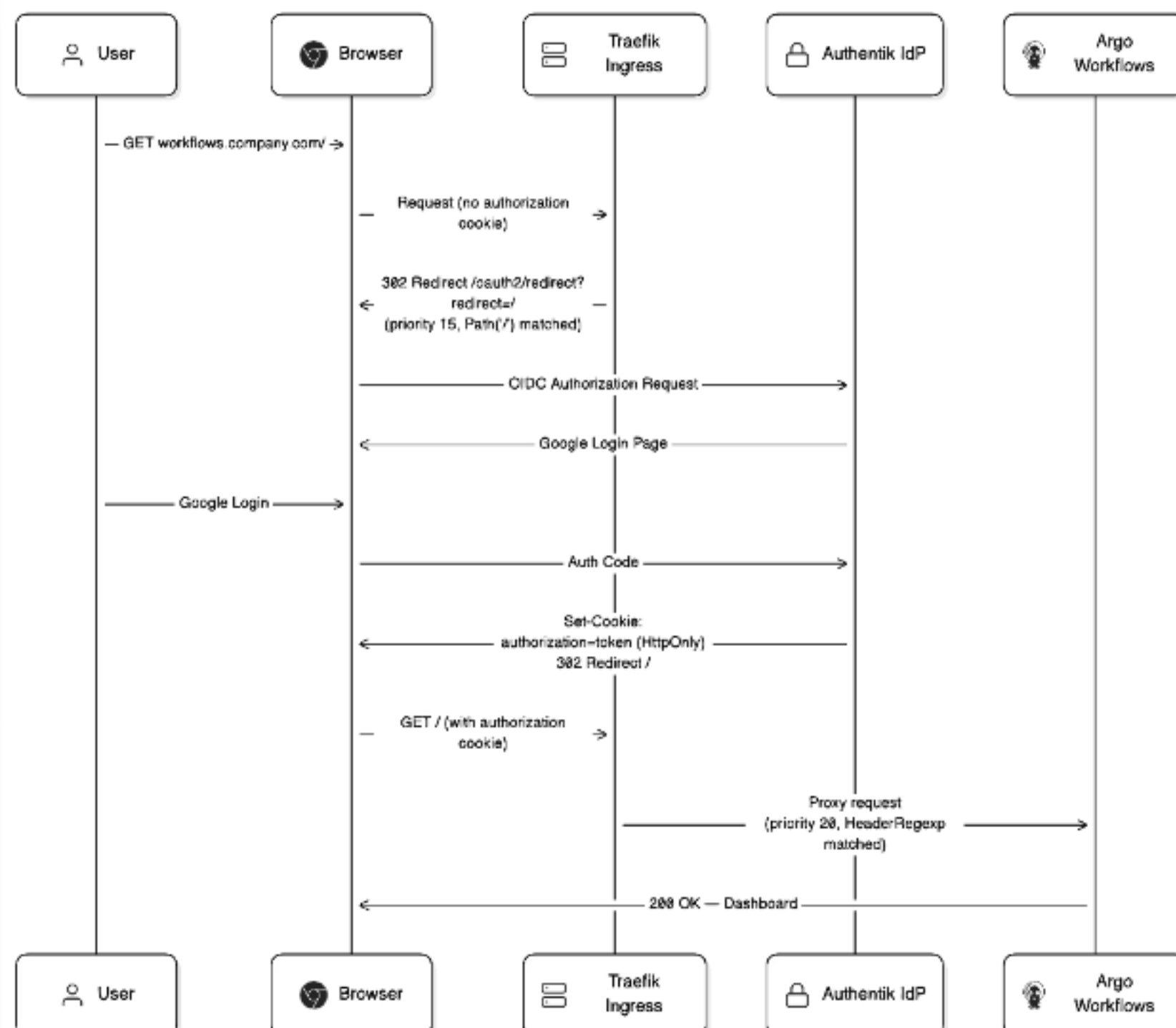
IAM User 없이 Authentik이 IdP 역할, 임시 자격증명 발급

Argo Workflows 무한 리다이렉트

Traefik 미들웨어로 SSO 리다이렉트를 걸었는데, 로그인 완료 후 다시 리다이렉트가 반복됐다. SSO 콜백 후 설정되는 authorization 쿠키 유무로 라우트를 분기해서 해결했다. Traefik v3에서 HeadersRegexp가 HeaderRegexp(단수형)로 바뀐 문법 변경도 겹쳤다.

Before: / - SSO - 완료 - / - 또 SSO - 무한루프

After: 쿠키 있으면 바로 통과, 없으면 SSO로 이동



도입 전후 비교

가장 큰 성과는 보안 측면이다. IAM User 기반 장기 자격증명이 전면 제거됐고, AWS 콘솔도 SAML 임시 자격증명으로만 접근한다.

Before

서비스별 계정 수동 생성
서비스별 계정 수동 삭제
IAM User (장기 자격증명)
엑세스 키 수동 발급

After

Google 계정 + 그룹 추가 1번
Authentik 계정 비활성화 1번
SAML (임시 자격증명)
OIDC 자동 갱신

내 애플리케이션

Development



Production



Tools



마무리

처음엔 "SSO 하나 붙이면 되는 거 아냐?" 싶었는데, 앱마다 프로토콜이 달랐고 K8s 버전 변경, Traefik v3 마이그레이션까지 맞물려 생각보다 손이 많이 갔다.

- 신규 서비스 추가 시 Blueprint에 앱 하나 추가하면 끝
- 장기 자격증명(IAM User) 전면 제거
- GitOps로 SSO 설정까지 코드로 관리

b100to.github.io